Machine Learning Approaches to Phishing Website Detection

Rakhat Bektas

COMP 4980: Special Topics – Machine Learning

Thompson Rivers University

December 2, 2024

1. Data Description

The dataset[1] analyzed contains information about different URLs of websites and characteristics that could indicate if a given site is a legitimate site or a phishing. Each record represents a single URL along with features that describe its structural attributes and the particular HTML elements in it. These features include the type of protocol used (e.g. does HTTPS exist), number of special characters in the URL, and the presence or absence of features such as forms or submit buttons in the HTML.

For cybersecurity focused research, this dataset is crucial to identify phishing websites: malicious sites with the intention of deceiving users to believe they are legitimate sites and steal their personal information. The benefit of phishing detection is that these sites can often get past conventional security filters, so the need for internet security is increased. The dataset is first examined for the characteristics of URLs, which forms the basis for building a predictive model to distinguish phishing sites from the legitimate ones based on particular patterns.

1.1. Dataset Characteristics

Data Type:

- The data consists of various types, including categorical, scalar, and textual data:
- Categorical data represents binary values like HTTPS presence (1 or 0).
- Scalar values (numerical counts) show counts for certain HTML elements (e.g., number of images, number of JavaScript files).

Text data (URLs) allows for derived metrics, such as similarity to known safe URLs.

Volume:

This dataset is moderately sized, containing 175974 unique values in a *URL* column. Such volume is manageable, making it appropriate for most machine learning algorithms without requiring extensive computational resources.

The dataset includes the following variables:

URL-based features:

- *URL*: The actual URL of the website being analyzed.
- *Domain*: The domain name of the website.
- *TLD*: The top-level domain (TLD), such as .com, .org, or .edu.
- *URLSimilarityIndex*: Degree of similarity between the URL and known legitimate URLs.
- *NoOfOtherSpecialCharsInURL*: Number of special characters (other than standard ones like slashes) found in the URL.
- *SpecialCharRatioInURL*: Ratio of special characters to the total number of characters in the URL.
- *IsHTTPS*: Indicates whether the URL uses the secure HTTPS protocol.

HTML-based features:

- *LineOfCode*: The total number of lines of code in the webpage's HTML.
- *Title*: The title tag of the webpage.
- *DomainTitleMatchScore*: A score indicating the match between the domain name and the webpage title.
- *URLTitleMatchScore*: A score indicating the match between the URL and the webpage title.

- *IsResponsive*: Indicates whether the webpage is responsive (i.e., adapts to different screen sizes).

Content-based features:

- *HasDescription*: Presence of a description meta tag on the webpage.
- *HasSocialNet*: Indicates whether the webpage contains social media links or buttons.
- *HasSubmitButton*: Presence of a submit button or form on the webpage.
- *HasCopyrightInfo*: Indicates if the webpage contains copyright information.
- Structural features:
- *NoOfImage*: The number of image tags (<img>) on the webpage.
- *NoOfJS*: The number of JavaScript tags (<script>) on the webpage.
- *NoOfSelfRef*: The number of self-referencing links (links pointing to the same domain) on the webpage.

Target Label: A *label* indicating if the URL is legitimate(1) or phishing(0).

Format:

The dataset is stored in Excel format (.xlsx), which is widely compatible with Python libraries like pandas. The structure allows for quick data loading and initial exploration.

2. Data Analysis

After looking at the generated heat map of dataset(see in Figure 1), key features were chosen based on their weight on ‘label’ feature and the ease of obtaining them from the website html directly. For example, the *URLSimilarityIndex* feature in the dataset is a value of the technique[2] for detecting visually similar phishing attacks through the identification of deceptive URL

patterns including zero width characters, homographs, punycode, homophones, and domain squatting techniques[pp2,3]. Calculating it in a real time browser extension is very difficult as it involves computationally intensive string analysis and pattern matching for a variety of obfuscation techniques which can slow down the user's browsing experience. Furthermore, the implementation of this index in a scalable fashion for various security profiles requires a strong framework with incremental learning and pre-training to accommodate new attack patterns and retain adaptability.

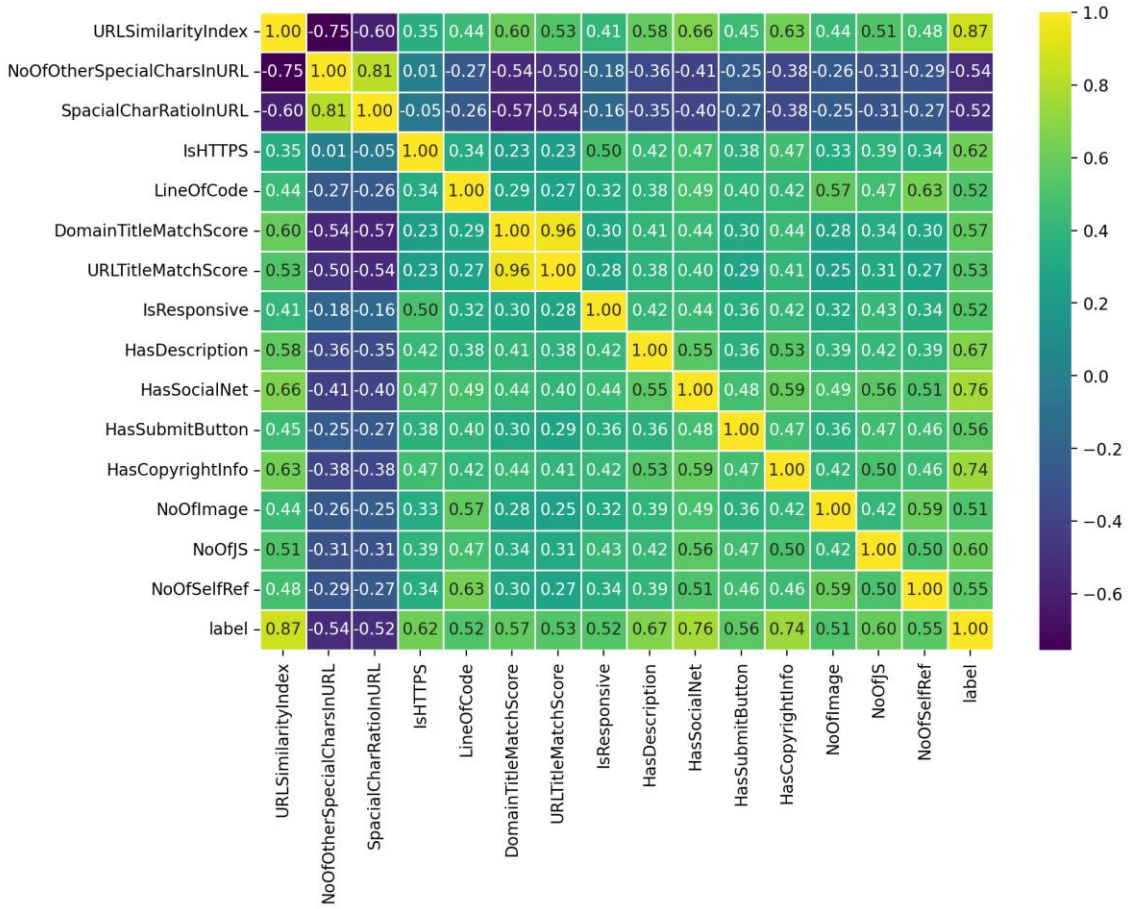


Figure 1. Heat map

The values chosen are: *IsHTTPS, HasDescription, HasSocialNet, HasCopyrightInfo, NoOfImage, NoOfJS*;

The values were chosen because they have a relatively heavy weight on *label* feature and they are easy to obtain from HTML. Some of them are very easy to get such as *IsHTTPS* and other will need to calculate the number of <tag> of certain values which is also relatively easy to obtain.

By looking at the Figure 2, the data results show that the majority of websites in the dataset have a secure HTTPS connection (mean of 0.79) and a lot of variation in features such as the number of images (mean of 19.61) and JavaScript files (mean of 9.45). The presence of features like descriptions, social network links and copyright information are less common, and have median values near zero, suggesting a prevalence of missing or absent data for these attributes. But still more data used the better for the model, especially when these data values are obtainable from HTML and relatively easy to calculate.

	mean	median	mode	min	max	std
IsHTTPS	0.790437	1.0	1	0.0	1.0	0.406998
HasDescription	0.447136	0.0	0	0.0	1.0	0.497199
HasSocialNet	0.461631	0.0	0	0.0	1.0	0.498527
HasCopyrightInfo	0.486009	0.0	0	0.0	1.0	0.499806
NoOfImage	19.612026	9.0	0	0.0	264.0	30.248986
NoOfJS	9.449927	6.0	0	0.0	77.0	12.019118

Figure 2. Mean, media, mode, min, max values

3. Data Exploration

3.1. Principal Component Analysis (PCA)

A cumulative explained variance plot based on the PCA analysis of the selected features (*IsHTTPS, HasDescription, HasSocialNet, HasCopyrightInfo, NoOfImage,* and *NoOfJS*) provided in the Figure 3, reveals that the first five principal components explain about 96% of

the variance in the dataset. This suggests that the first five components capture most of the important patterns in the data, and the sixth component is not adding very much variance. The analysis also shows that some features may be overlapping or sharing information, so that so much of the variance can be explained by fewer components. This implies that model may be able to work with less components, but still not certain whether it would achieve the same model performance with as few as five components. That would need more testing to confirm.

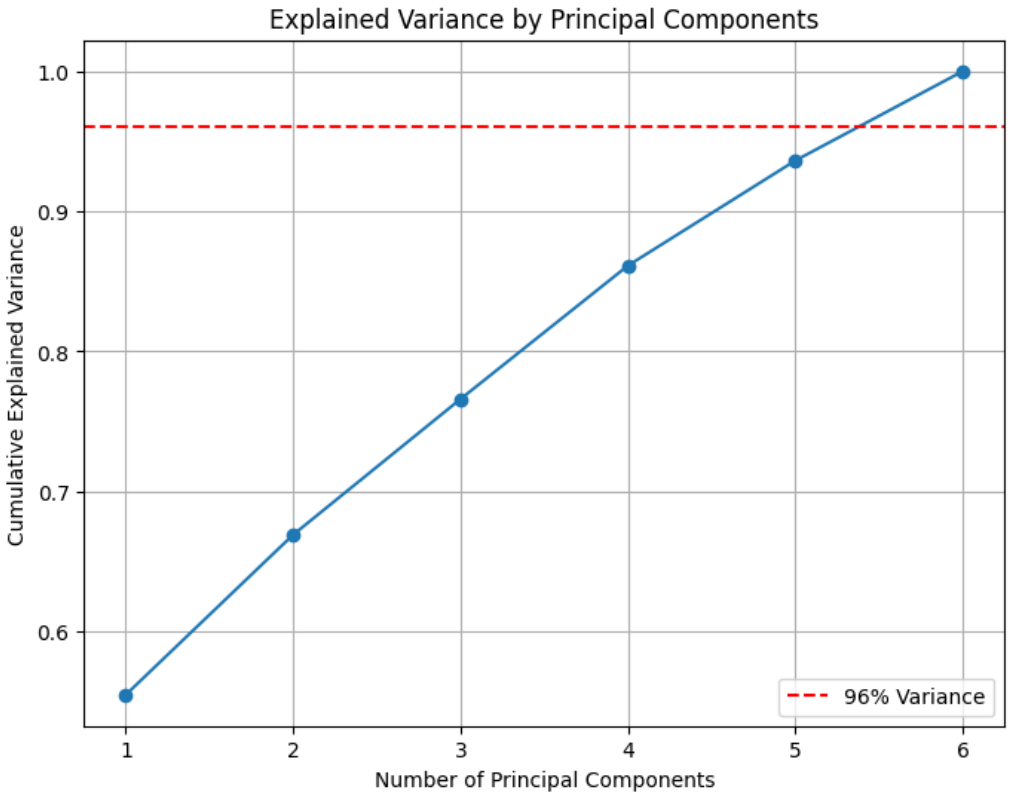


Figure 3. Explained Variance by Principal Components

3.2 Decision Trees

When training the Decision Tree model on the selected features (*IsHTTPS, HasDescription, HasSocialNet, HasCopyrightInfo, NoOfImage, NoOfJS*), it resulted in strong performance with accuracy of around 98.37%(see in Figure 4). The confusion matrix indicates

that the model correctly classified the majority of legitimate (class 1) and phishing (class 0) samples, with relatively low misclassification rates: model indicated 242 false positives (legitimate sites misclassified as phishing) and 334 false negatives (phishing sites misclassified as legitimate).

The results of the classification accuracy further reinforces the effectiveness of the model with the precision, recall and F1 – score being close to 0.98 or higher for both classes. This implies that the model performs well in identifying phishing sites as well as avoiding false alarms in legitimate ones.

```
Accuracy: 0.9836609650242533
Confusion Matrix: [[14166   242]
 [  334 20511]]

Classification Report:
              precision    recall  f1-score   support

           0       0.98      0.98      0.98     14408
           1       0.99      0.98      0.99     20845

    accuracy                           0.98     35253
   macro avg       0.98      0.98      0.98     35253
weighted avg       0.98      0.98      0.98     35253
```

Figure 4. Accuracy results of Decision Tree

Based on the visualization of the Decision Tree in Figure 5, seems that features like *NoOfImage* and *HasCopyrightInfo* are very important early splits (have a big effect on the classification). The Decision Tree is allowed to grow up to 8 levels deep and this is what the model uses. This restriction prevents the model from becoming too complex and overfitting the training data. The depth is limited in the tree so the most significant features and patterns are focused on, and the risk of capturing noise in the data is reduced.

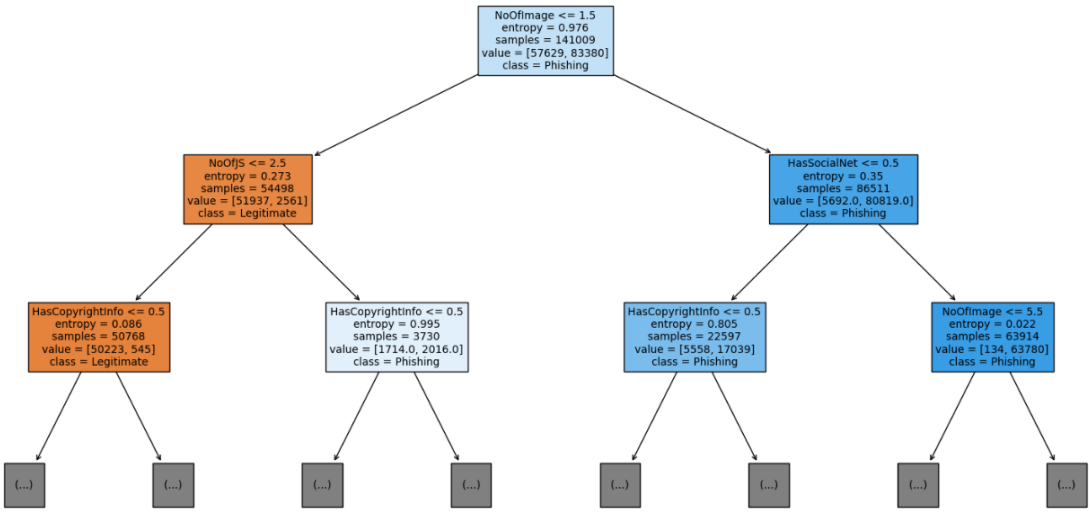


Figure 5. Visualization of the Decision Tree

4. Experimental Method

4.1. Logistic Regression

The first approach was to try the dataset with Logistic Regression, which is a basic and well known machine learning algorithm. The results of Logistic Regression described by Figure 6 were satisfactory, with an accuracy of about 97.6%. While the model was overall effective, it wasn't perfect at identifying websites correctly. This is proven in the confusion matrix, some phishing websites were misclassified as legitimate and some legitimate websites were misclassified as phishing. Logistic Regression may not be able to fully account for the complexity or subtle patterns in the dataset, as these misclassifications suggest, and it may be necessary to look into more algorithms in order to achieve better performance.

```
Logistic Regression Predictions: [1 1 0 1 1 0 0 1 0 1]
Logistic Regression Accuracy: 0.9758602104785409
Confusion Matrix:
 [[14083   370]
 [  481 20319]]
```

Figure 6. Accuracy results of Logistic Regression model

4.2. Random Forests

Although random forest is a very popular method for solving classification tasks, results displayed in Figure 7 by were disappointing. The mean score of cross validation was 59.09(see Figure 8), which was approximately 59.1% of accuracy.

```
Accuracy: 0.5911837290443367
Confusion Matrix:
[[   21 14387]
 [   25 20820]]
Classification Report:
              precision    recall  f1-score   support

           0       0.46      0.00      0.00     14408
           1       0.59      1.00      0.74     20845

    accuracy                           0.59     35253
   macro avg       0.52      0.50      0.37     35253
weighted avg       0.54      0.59      0.44     35253
```

Figure 7. Accuracy results of Random Forest

```
Cross-validation scores: [0.590951   0.59116375 0.59098645 0.59091554 0.59072373]
Mean cross-validation score: 0.5909480939205248
```

Figure 8. Results of Random Forest after cross-validation

The confusion matrix showed a large problem with classifying legitimate websites (label 0). The model performed almost perfectly on phishing websites (label 1), but misclassified almost all

legitimate websites as phishing. This was further evident in the weighted average *F1-score* of 0.44, which means that the model was not able to strike a good balance in its predictions.

Random Forest was not as good as Logistic Regression. An accuracy of 97.6% was achieved by Logistic Regression and it was much better balanced in predicting phishing and legitimate websites. Logistic Regression performed remarkably well, indicating that the features in the dataset do not need complex interactions to separate the two classes well.

The aggregated performance of Random Forest was expected to be better than Decision Trees, which is the base of the Random Forest algorithm, however, it wasn't. This could be because of the `max_depth=8` parameter which might have constrained the complexity of the individual trees, thus not allowing the model to capture the underlying patterns in the data completely. One of the trees was visualized which is shown in Figure 6, and features including *NoOfImage*, *HasDescription*, and *HasSocialNet* were found to be important in the decision making process, however the splits were not able to effectively reduce uncertainty, as seen by the relatively high *Gini* indices at each node.

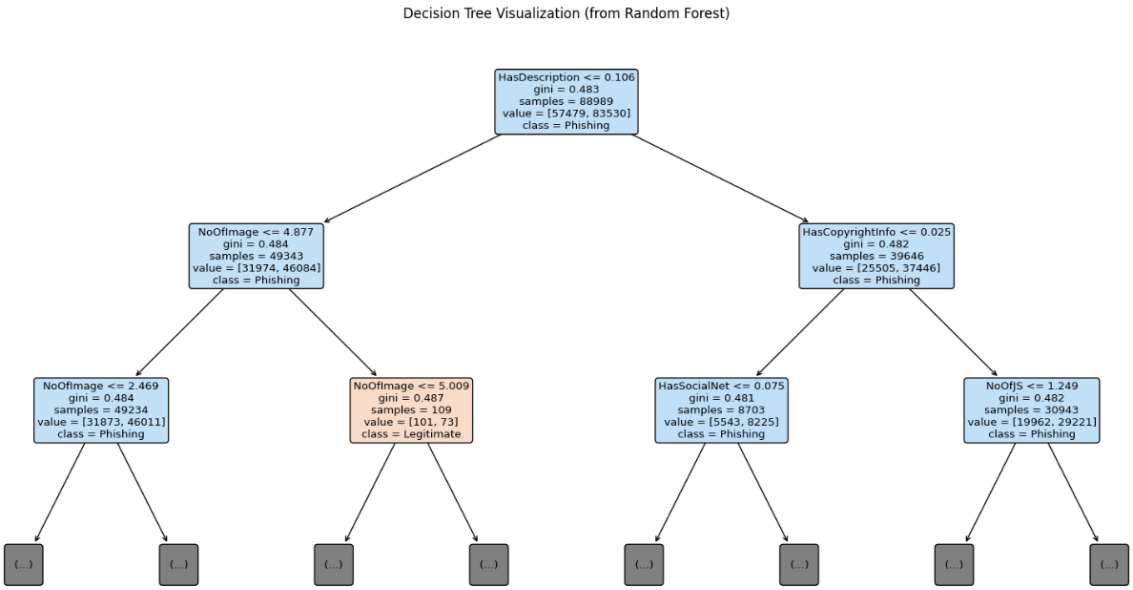


Figure 6. Visualization of one tree from Random Forest

In general, the Random Forest model did not perform as good as expected, and it was worse than Logistic Regression, which was a simpler model and yielded much better results.

5. Results & Analysis

To compare these algorithms, they were tested to determine their ability to classify websites as either phishing or legitimate. The primary goal of this project was to develop a model capable of identifying whether a website is phishing or legitimate based solely on its URL. Various functions were implemented to support the algorithms, including one that extracts data for training the models directly from the HTML of a website's URL.

The classification results for each algorithm are summarized as follows:

- Decision Tree: It correctly classified both URLs, predicting "1" (legitimate) for the legitimate site and "0" (phishing) for the phishing site.

```
Decision Tree's Legitimate Site Prediction: 1
Decision Tree's Phishing Site Prediction: 0
```

Figure 7. URLs prediction results of Decision Tree

- Logistic Regression: Classified the legitimate site ("1") and misclassified the phishing site ("1").

```
Logistic Regression's Legitimate Site Prediction: 1
Logistic Regression's Phishing Site Prediction: 1
```

Figure 8. URLs prediction results of Logistic Regression

- Random Forest: Logistic Regression produced the same results as it correctly predicted the legitimate site but incorrectly labeled the phishing site as legitimate.

```
Random Forest's Legitimate Site Prediction: 1
Random Forest's Phishing Site Prediction: 1
```

Figure 9. URLs prediction results of Random Forest

Results show that the Decision Tree performed better than the other two models in this particular test, correctly classifying phishing and legitimate websites.

5.1. The Practical Implications and Challenges.

Initial results show that Decision Tree algorithm is the most efficient model for detecting phishing websites. However, these findings must be validated with additional testing on a larger and more varied dataset. The main limitation of the project is that real world phishing URLs for testing are not available. Phishing websites are hard to access since many are quickly removed or flagged by browsers. This limitation highlights the importance of future work that focuses on

obtaining and testing with more representative datasets to ensure that the model is robust and applicable to the real world.

The findings of this project reveal that machine learning has the potential to improve phishing detection systems. With further refinement and additional testing, the proposed approach could be a useful tool in the protecting from phishing websites stealing user information.

References

1. Prishasawhney. Phishing URL Website Dataset (Cleaned) [Internet]. Kaggle; 2023 [cited 2024 Dec 1]. Available from: https://www.kaggle.com/datasets/prishasawhney/phishing-url-website-dataset-cleaned/data

2. Prasad A, Chandra S. PhiUSIIL: A diverse security profile empowered phishing URL detection framework based on similarity index and incremental learning. Computers & Security [Internet]. 2024 Jan 1 [cited 2024 Dec 1];136. Available from: https://research-ebsco-com.ezproxy.tru.ca/linkprocessor/plink?id=75a7ab1d-27eb-3981-adc1-b4e1f602f4c6